REPUBLIQUE DU CAMEROUN
Paix – Travail – Patrie

UNIVERSITE DE YAOUNDE I

ECOLE NATIONALE SUPERIEURE POLYTECHNIQUE DE YAOUNDE

DEPARTEMENT DE GENIE INFORMATIQUE

REPUBLIC OF CAMEROON
Peace – Work – Fatherland

UNIVERSITY OF YAOUNDE I

NATIONAL ADVANCED SCHOOL OF ENGINEERING OF YAOUNDE

DEPARTMENT OF COMPUTER SCIENCE

Charte de Gouvernance de la Sécurité des Systèmes d'Information

Entreprise LiZbiZ

DEVOIR INDIVIDUEL

Cybersécurité & Investigation Numérique

Proposition de charte pour le Comité de Direction

RÉALISÉ PAR

22P035 : MBETSI DJOFANG

Niveau : 4 CIN

SUPERVISEUR

M. MINKA

Année Académique : 2025 – 2026

Table des Matières

1 Préambule et Contexte Opérationnel **3**
- 1.1 Vulnérabilités organisationnelles identifiées . . . 3
- 1.2 Objectifs de cette charte . . . 3

2 Architecture de Gouvernance : Le Rôle du RSSI **4**
- 2.1 Positionnement hiérarchique . . . 4
- 2.2 Fiche de poste synthétique . . . 5

3 Matrice RACI — Gestion des Incidents Critiques **6**
- 3.1 Légende RACI . . . 6
- 3.2 Matrice opérationnelle . . . 6

4 Analyse Critique et Justification **7**
- 4.1 Indépendance du RSSI : une nécessité structurelle . . . 7
- 4.2 Principes structurants de la matrice RACI . . . 7
  - 4.2.1 Unicité du *Accountable* . . . 7
  - 4.2.2 Séparation communication / technique . . . 7
  - 4.2.3 RETEX sous responsabilité de la Direction Générale . . . 7

5 Feuille de Route et Prochaines Étapes **8**
- 5.1 Plan d'action immédiat . . . 8
- 5.2 Indicateurs de performance clés (KPIs) . . . 8

6 Conclusion **9**

1 | Préambule et Contexte Opérationnel

Situation critique identifiée

LiZbiZ fait face à une **dette de sécurité structurelle**. La croissance rapide de l'entreprise, son introduction en bourse imminente et les exigences réglementaires (**RGPD**, **PCI-DSS**) imposent une refonte complète de la gouvernance SSI.

1.1 Vulnérabilités organisationnelles identifiées

- **Poste de RSSI vacant** — Aucun responsable dédié à la sécurité des SI.
- **Cumul DSI/RSSI** — Sophie M. cumule les fonctions opérationnelles et de contrôle, créant un **conflit d'intérêts majeur** (juge et partie).
- **Absence de processus formels** — Pas de procédure documentée de gestion des incidents, pas de Plan de Gestion de Crise (PGC).
- **Conformité à risque** — Non-conformité potentielle au RGPD et PCI-DSS, exposant LiZbiZ à des sanctions financières et réputationnelles.

1.2 Objectifs de cette charte

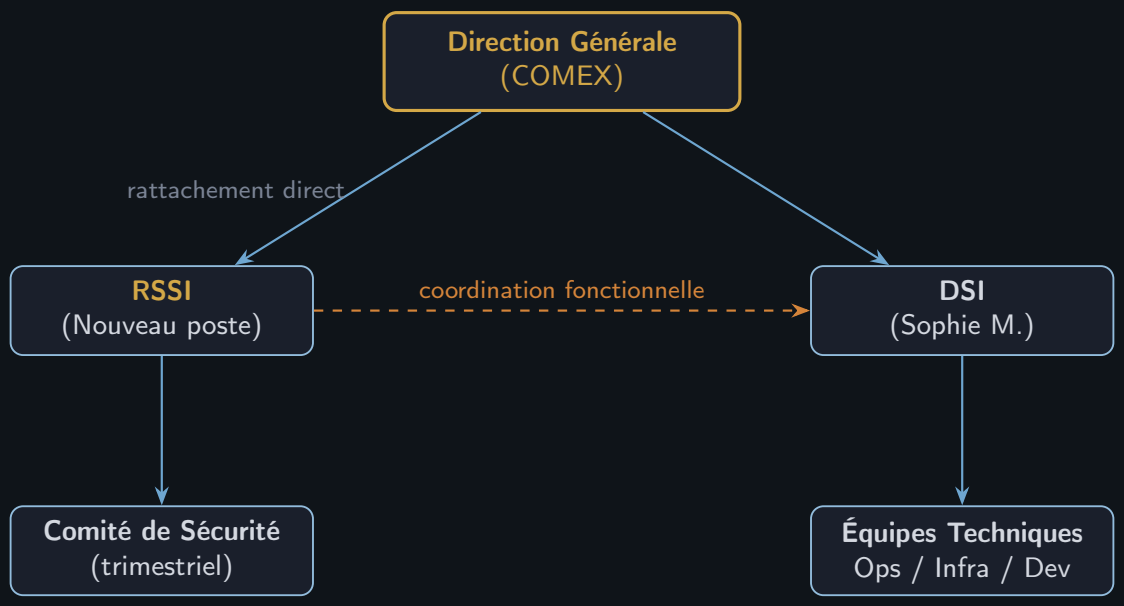
1. **Clarifier les rôles et responsabilités** en matière de sécurité du SI.
2. **Établir une gouvernance formelle** avec un RSSI dédié et indépendant.
3. **Assurer l'alignement stratégique** de la sécurité avec les objectifs métier (livraison 24h, confiance des clients et investisseurs).
4. **Préparer LiZbiZ** aux certifications **ISO 27001** et aux audits réglementaires.

2 | Architecture de Gouvernance : Le Rôle du RSSI

2.1 Positionnement hiérarchique

Principe fondamental

Le RSSI est rattaché **directement à la Direction Générale**, et **non** à la DSI. Cette indépendance est **non négociable** : elle garantit que les décisions de sécurité ne sont pas subordonnées aux contraintes opérationnelles ou budgétaires de la DSI.



2.2 Fiche de poste synthétique

Domaine	Description
Périmètre	Définir, mettre en œuvre et piloter la Politique de Sécurité du SI (PSSI). Cartographier les risques et maintenir le registre des traitements.
Reddition	Présenter **annuellement** un état des risques et un plan d'action au COMEX. Rendre compte des incidents majeurs sous **48h** à la Direction Générale.
Conformité	Assurer la conformité **RGPD**, **PCI-DSS**. Piloter la démarche de certification **ISO 27001**. Coordonner avec le DPO.
Animation	Présider le Comité de Sécurité trimestriel. Piloter les campagnes de sensibilisation et les exercices de simulation (phishing, crise).
Veille	Assurer une veille continue sur les menaces (CTI), les vulnérabilités et l'évolution réglementaire.
Limites	Le RSSI **ne réalise pas** l'exécution technique (administration des serveurs, firewalls). Il pilote le *quoi faire* ; la DSI exécute le *comment*.

3 | Matrice RACI — Gestion des Incidents Critiques

Périmètre d'application

Cette matrice s'applique aux **incidents critiques** : ransomware, fuite de données massive, compromission de comptes privilégiés, attaque DDoS prolongée. Elle sera intégrée au futur **Plan de Gestion de Crise (PGC)**.

3.1 Légende RACI

- **R** — **Responsible** — Réalise l'action opérationnellement.
- **A** — **Accountable** — Valide la décision, détient l'autorité ultime. *Un seul par activité.*
- **C** — **Consulted** — Apporte son expertise avant la prise de décision.
- **I** — **Informed** — Est tenu informé du résultat après action.

3.2 Matrice opérationnelle

Phase / Activité	DG	DSI	RSSI	DRH	DirCom
1. Détection & Qualification	I	C	A/R	I	I
2. Déclenchement Cellule de Crise	A	C	R	C	C
3. Confinement technique	I	A	C	–	–
4. Communication Interne	I	I	C	R	A
5. Communication Externe	A	I	C	I	R
6. Investigation forensique	I	C	A/R	–	–
7. Remédiation & PRA	I	A	C	–	–
8. Retour d'Expérience (RETEX)	A	C	R	C	C

4 | Analyse Critique et Justification

4.1 Indépendance du RSSI : une nécessité structurelle

Analyse de risque organisationnel

Le cumul actuel des fonctions DSI/RSSI par Sophie M. constitue une **vulnérabilité organisationnelle critique**. En sécurité de l'information, deux fonctions doivent rester séparées :

- **L'exécution** (construire et maintenir le SI) → rôle de la **DSI**.
- **Le contrôle** (vérifier que le SI est sûr) → rôle du **RSSI**.

Quand la même personne construit *et* contrôle, elle est **juge et partie**. C'est l'équivalent d'un auditeur financier qui serait aussi le comptable : le dispositif perd toute crédibilité vis-à-vis des régulateurs et des investisseurs.

4.2 Principes structurants de la matrice RACI

4.2.1 Unicité du *Accountable*

Pour chaque activité, **un seul décideur** détient l'autorité finale. En situation de crise, l'ambiguïté décisionnelle est l'ennemi n°1. La matrice garantit qu'à chaque instant, une personne — et une seule — peut trancher.

4.2.2 Séparation communication / technique

Règle d'or en gestion de crise

En cas de crise, la **DirCom** est le seul porte-parole autorisé vers l'extérieur. Le DSI et le RSSI sont **consultés** pour la précision technique, mais ne s'adressent **jamais** directement à la presse ou aux clients. Objectif : maîtriser le narratif et éviter le jargon technique.

4.2.3 RETEX sous responsabilité de la Direction Générale

Le retour d'expérience post-incident n'est **pas un exercice technique**. C'est un acte **managérial** qui doit se traduire par :

1. Des **décisions budgétaires** (investissements sécurité).
2. Des **modifications organisationnelles** (processus, formations).
3. Des **engagements mesurables** (KPIs de sécurité).

La DG est **Accountable** du RETEX car elle seule peut transformer les leçons en actions concrètes et financées.

5 | Feuille de Route et Prochaines Étapes

5.1 Plan d'action immédiat

#	Action	Délai	Porteur
01	Validation de la charte en COMEX	J+0	DG
02	Nomination d'un RSSI par intérim	J+7	DG
03	Lancement du recrutement RSSI	J+15	DRH + DG
04	Rédaction du PGC (v1)	J+30	RSSI intérim
05	Premier exercice de crise simulé	J+60	RSSI + DSI
06	Audit de conformité RGPD / PCI-DSS	J+90	RSSI + DPO
07	Démarrage certification ISO 27001	J+120	RSSI

5.2 Indicateurs de performance clés (KPIs)

Métriques de suivi trimestriel

Le RSSI rendra compte trimestriellement des indicateurs suivants au COMEX :

- **MTTD** (*Mean Time To Detect*) — Temps moyen de détection d'un incident. **Cible : < 4h**.
- **MTTR** (*Mean Time To Respond*) — Temps moyen de réponse et confinement. **Cible : < 2h**.
- **Taux de conformité** — Pourcentage de contrôles RGPD/PCI-DSS satisfaits. **Cible : > 90%**.
- **Taux de sensibilisation** — Pourcentage de collaborateurs formés. **Cible : 100%/an**.
- **Taux de clics phishing** — Résultat des campagnes de simulation. **Cible : < 5%**.

6 | Conclusion

Synthèse exécutive

Cette charte de gouvernance répond aux trois urgences de LiZbiZ :

1. **Formaliser un rôle de contrôle indépendant** — Le RSSI, rattaché à la Direction Générale, élimine le conflit d'intérêts actuel et donne à la sécurité une voix au plus haut niveau décisionnel.
2. **Sécuriser la gestion des incidents** — La matrice RACI garantit qu'en cas de crise, chaque acteur connaît son rôle, éliminant l'improvisation et les délais fatals.
3. **Préparer l'avenir** — En structurant la gouvernance SSI, LiZbiZ se dote des fondations nécessaires pour sa certification ISO 27001, sa conformité réglementaire et la confiance de ses investisseurs.

Recommandation : validation immédiate par le COMEX

Lancer le recrutement du RSSI et intégrer ces principes dans les procédures opérationnelles de la DSI et des RH.

Document préparé pour le Comité de Direction — LiZbiZ

Classification : **Confidentiel**